信息安全测评与风险评估

8.1 资产识别与CIA赋值

授课教师：张玉



目录

CONTENTS

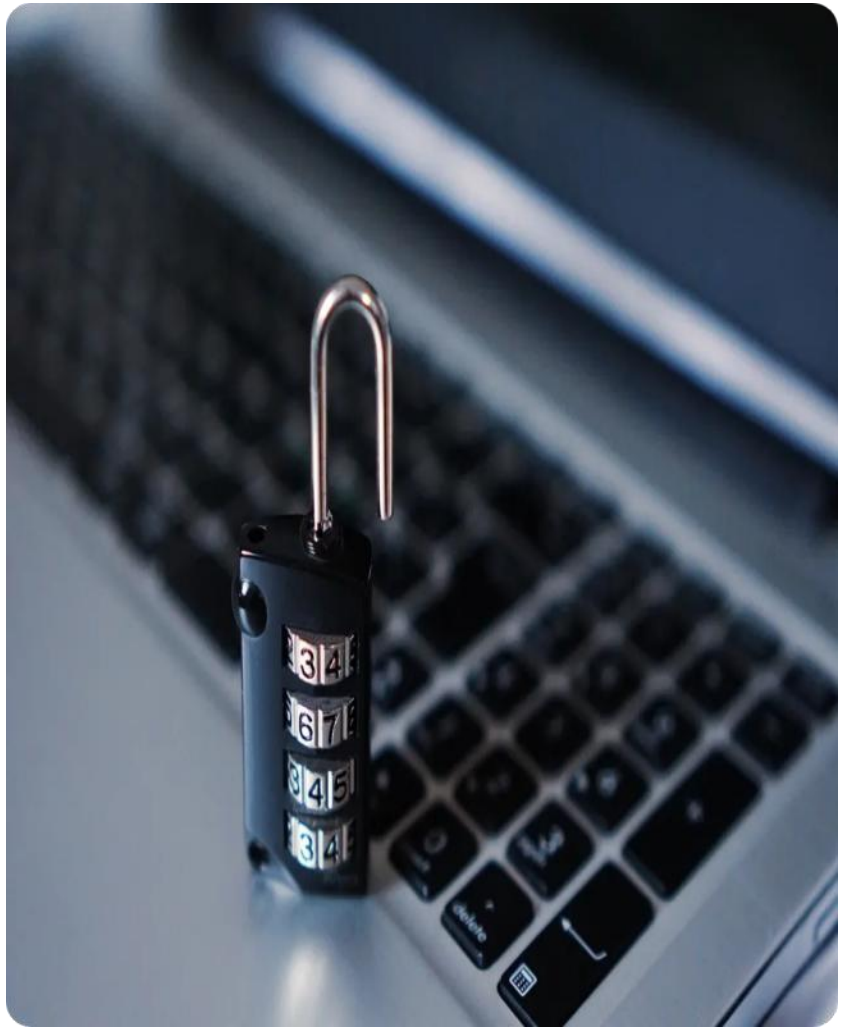
01 案例导入——“你保护的是什么？”

02 学习目标

03 资产的分类——新版GB/T 20984的三层结构

04 传统资产分类方法（旧版GB/T 20984）

案例导入——“你保护的是什么？”



引入：你要保护一座房子，首先得知道——房子里有什么是值钱的？

案例： 2017年9月，美国征信巨头Equifax宣布数据泄露：约1.47亿人的姓名、社保号、住址被窃取——几乎半个美国的信用档案暴露。

调查发现：

- 没人知道多少台服务器在跑该组件；修复清单漏掉几十台系统；管理层答不上来“到底有哪些资产”

核心问题

如果连“自己有哪些资产、哪些最敏感”都答不上来，后面的漏洞扫描、补丁管理、风险计算会怎样？

学习目标

理解	掌握	掌握	能够	为
资产识别在风险评估中的核心地位	资产的分类方法（业务资产、系统资产、组件资产）	CIA三性赋值的标准方法（5级制）	独立编制资产清单并进行资产价值计算	后续威胁识别、脆弱性识别奠定基础

什么是资产？

GB/T 20984-2022 定义

资产是对组织有价值的任何东西，包括信息资产、软件资产、硬件资产、服务资产、人员资产等。

通俗理解：资产 = 需要保护的东西

可以是有形的

服务器、防火墙、门禁

也可以是无形的

数据、声誉、人员

“没有资产清单，就没有安全保护。”

“三无资产”的教训

在攻防演练中，很多系统被攻破不是因为安全设备买得不够，而是因为资产不清楚——

存在

“无负责人、无标识、无维护”

的“三无资产”。

资产的分类——新版GB/T 20984的三层结构

业务资产（组织的核心业务与服务）

例：“电子政务服务平台”“医院HIS系统”“电商交易系统”

↓

系统资产（支撑业务运行的信息系统）

例：HIS系统、LIS系统、PACS系统、门户网站

↓

组件/单元资产（构成信息系统的具体组件）

例：数据库服务器、Web服务器、防火墙、网络设备、应用软件

关键理解： 新版标准以“业务”为核心进行风险评估，而非以“单一资产”为核心。

传统资产分类方法（旧版GB/T 20984）



素材3：参考标准
——GBT 20984 资

虽然新版引入了三层结构，但组件层面的资产分类仍然适用。课程中以组件资产为主要操作对象，结合业务视角理解整体。

资产类别	包含内容	举例
硬件资产	物理设备	服务器、网络设备、存储设备、终端设备
软件资产	应用软件、系统软件	操作系统、数据库、业务应用、中间件
数据资产	各类数据	业务数据、配置数据、审计日志、用户信息
人员资产	人员与岗位	管理员、操作员、开发人员、外包人员
服务资产	内外部服务	运维服务、云服务、第三方接口

资产识别五步法

实践中如何一步步完成资产识别？

1 确定评估范围

明确涉及的业务、系统、网络区域

2 收集资产信息

通过文档、访谈、现场、工具等收集

3 资产分类

按业务→系统→组件层次分类

4 资产赋值

对资产CIA三性进行赋值（1-5级）

5 编制资产清单

形成正式的清单文档

⚠ 注意事项：

- 对关键资产应进行现场查看，不能仅凭文档
- 资产价值随时间变化，应定期更新
- 跨部门/地域系统，分清边界非常重要

– CIA三性——评估资产的三个维度

CIA是信息安全的“铁三角”，也是资产价值评估的核心依据。

C 机密性

Confidentiality

含义

信息不被未授权者获取

核心问题

“数据被泄露了，损失有多大？”

I 完整性

Integrity

含义

信息不被未授权篡改

核心问题

“数据被篡改了，后果有多严重？”

A 可用性

Availability

含义

信息在需要时能够被正常访问

核心问题

“系统宕机了，影响有多大？”

机密性（C）赋值详解

素材1：资产赋值速查卡（学生

机密性关注：信息泄露会造成多大损失？

5级 – 很高：包含组织最重要的秘密，泄露会对组织造成灾难性损害，对国家安全造成严重损害。

4级 – 高：包含组织的重要秘密，泄露会使组织安全和利益遭受严重损害，对国家安全造成较大损害。

3级 – 中等：包含一般性秘密，泄露会使组织安全和利益受到损害，对国家安全造成一定损害。

2级 – 低：仅限内部公开的信息，向外扩散可能造成轻微损害。

1级 – 很低：可对社会公开的信息，泄露几乎无影响。

举例：

5 **患者诊疗数据：**包含个人隐私，泄露后果极其严重。

3 **系统配置文件：**泄露可能暴露系统架构，但非核心秘密。

1 **公司官网公开信息：**本就是公开内容。

完整性（I）赋值详解

完整性关注：数据被篡改会造成多大损失？

五级赋值标准

5级 很高	完整性价值极其关键，篡改或破坏会造成无法接受的损害，难以弥补
4级 高	完整性价值较高，篡改或破坏会造成重大影响，较难弥补
3级 中等	完整性价值中等，篡改或破坏会造成明显影响，可以弥补
2级 低	完整性价值较低，篡改或破坏会造成轻微影响，容易弥补
1级 很低	完整性价值非常低，篡改或破坏的影响可以忽略

典型场景举例

对应 5级

患者诊疗数据

病历篡改可能导致医疗事故，危及生命

对应 4级

操作日志

篡改日志会掩盖攻击行为，影响追溯

对应 1级

临时缓存文件

篡改影响极小

可用性（A）赋值详解

可用性关注　系统中断会造成多大损失？

五级赋值标准：

5级	很高：	不允许中断，对业务造成灾难性影响或损害国家安全
4级	高：	允许中断 < 10分钟，中断会造成重大影响
3级	中等：	允许中断 < 30分钟，中断会造成明显影响

5级

医院HIS系统

系统停机将无法挂号、缴费、开药，业务瘫痪

3级

门户网站

短暂中断影响用户体验，但不致命

1级

内部测试环境

中断几乎不影响业务

资产价值计算——如何综合赋值？

资产价值 = 从C、I、A三个维度综合评定

最大值法

max(C, I, A)

保守型，就高不就低，取最高值

平均值法

(C + I + A) / 3

均衡型，适用于一般场景

加权法

w1×C + w2×I + w3×A

业务特点明确，不同属性不同重要性

- **平均值法计算示例**

HIS数据库

C=5, I=5, A=5，价值 (5+5+5)/3 = 5　等级：很高

门户网站

C=2, I=3, A=4，价值 (2+3+4)/3 = 3　等级：中等

临时缓存

C=1, I=1, A=2，价值 (1+1+2)/3 ≈ 1　等级：很低

计算区间(取整)	对应等级
4.5-5.0	很高
3.5-4.4	高
2.5-3.4	中等
1.5-2.4	低
1.0-1.4	很低

- **资产价值等级对应**

教师演示——资产赋值实操（15分钟）

演示场景： 某高校“教务管理系统”关键资产

素材2：资产清单与CIA赋值表.docx

1、展示系统架构图

识别主要资产组件

2、逐项分析资产

讨论各项资产的CIA等级

3、计算资产价值

使用平均值法计算

4、形成资产清单

汇总完整结果

实践任务1——资产识别与CIA赋值（20分钟）



素材4：实践任务——电商系统

任务名称及场景

任务名称：资产识别与CIA赋值实战

任务场景：模拟某小型电商公司“电商交易系统”，核心资产清单已提供

核心资产清单

① 用户数据库(姓名等)
② 商品信息库(含价格)
③ 订单数据
④ 支付接口
⑤ Web服务器
⑥ 数据库服务器

任务内容

① 对每项资产进行CIA三性赋值（1-5分）
② 计算各项资产的综合价值（平均值法）
③ 确定关键资产
④ 填写《资产清单与CIA赋值表》

时间安排：约20分钟

实践任务1——《资产清单与CIA赋值表》

资产编号	资产名称	资产类别	机密性(C)	完整性(I)	可用性(A)	资产价值	关键性说明
A-01							
A-02							
A-03							
A-04							
A-05							

填写说明：

资产类别：硬件/软件/数据/人员/服务

资产价值：使用平均值法，保留1位小数

C/I/A赋值：1-5分，参考PPT第10-12页的赋值表

关键性说明：简要说明为什么这个资产重要

实践任务2——关键资产识别（15分钟）

任务名称： 从资产清单中识别关键资产

任务场景： 延续任务1的资产清单结果

01 排序

将资产按价值从高到低排序

02 识别

识别出资产价值≥4的“关键资产”

03 讨论

为什么要优先保护关键资产？

04 思考

关键资产应该采取什么级别的保护措施？

资产识别中的常见错误

错误类型	错误做法	正确做法
遗漏资产	只关注IT设备，忽略数据、人员、文档	按资产分类全面识别
边界不清	混淆了评估范围，包含了不该包含的系统	明确定义评估边界
赋值主观	凭个人感觉随意赋值	参考标准赋值表，团队讨论确定
忽略业务关联	只看单一资产，不看业务影响	从业务视角评估资产重要性
一劳永逸	资产清单不再更新	定期更新资产清单

思政融入——资产识别中的责任与担当

责任

患者诊疗数据、公民个人信息——这些都是需要保护的重要资产

一次资产遗漏，可能造成无法挽回的损失

合规

《网络安全法》要求网络运营者履行安全保护义务

资产识别是合规的第一步

使命

作为未来的信息安全从业者，你的工作就是在保护这些“看不见的财富”

保护资产，就是在保护人民群众的切身利益——这是信息安全从业者的使命。

知识点回顾（5分钟）

思维导图（本课核心知识）

一、资产的概念
定义对组织有价值的任何东西，资产识别是第一步。

二、资产分类
三层结构（业务→系统→组件），五大类

三、资产识别五步法
确定范围→收集信息→资产分类→资产赋值→编制清单。

四、CIA三性赋值
机密性(C)、完整性(I)、可用性(A)，五级标准。

五、资产价值计算
最大值/平均值/加权法，价值等级(高至低)。

六、常见错误
遗漏资产、边界不清、赋值主观、忽略业务关联。

课后作业

必做	完成《资产清单与CIA赋值表》（基于课堂电商场景），提交至学习通平台
必做	完成活动8.1在线测试（选择题+判断题，共15题）
选做	以自己熟悉的一个系统为例，自行完成资产识别与CIA赋值
预习	预习8.2“威胁识别与赋值”相关内容

下节课预告

8.2 威胁识别与赋值

预告内容

- 威胁源与威胁行为方式分析
- 威胁可能性赋值方法
- 《威胁识别表》填写

课前准备

- 复习 GB/T 20984 中威胁识别的相关内容
- 了解常见威胁分类（自然、人为、系统）

课堂小结与答疑

3

核心知识点

① 资产识别是风险评估的第一步；

② CIA三性是资产价值评估的核心维度；

③ 资产价值综合评定方法（最大值法/平均值法/加权法）

2

关键技能

① 能对资产进行CIA三性赋值；

② 能编制资产清单

1

职业准则

保护资产就是保护人民群众的

输

感谢观看

